REPORT TECNICO SOC

Detection di attacchi Brute Force SSH con Splunk Enterprise (SIEM)
Analisi dei log di autenticazione, correlazione, tuning dei falsi positivi e dashboard operativa

Autore: Leonardo Onori

Data: 1 Novembre 2026

Ruolo simulato: Analista SOC L1

Framework di riferimento: MITRE ATT&CK – T1110 Brute Force

Componente	Dettaglio
Piattaforma SIEM	Splunk Enterprise 10.4.2 – licenza Free (attivata dopo la scadenza della licenza Enterprise Trial)
Host di analisi	EpicodeServer – Windows Server 2022, macchina virtuale di laboratorio
Dataset	Splunk Tutorial Data (`tutorialdata.zip`): log simulati dell'infrastruttura dell'e-commerce fittizio *buttercup-shopping*
Volume indicizzato	109.864 eventi in 3 sourcetype
Periodo coperto dai log	18 – 25 agosto 2026 (8 giorni, timestamp del dataset)
Sistemi analizzati	4 server Linux con SSH: `mailsv1` (posta), `www1`, `www2`, `www3` (web)
Deliverable	Query di detection SPL, dashboard Splunk "SOC – SSH Brute Force Detection", presente report

1. EXECUTIVE SUMMARY

Il presente report documenta l'analisi, condotta con il SIEM Splunk, dei log di autenticazione SSH di un'infrastruttura composta da quattro server Linux, con l'obiettivo di individuare tentativi di accesso non autorizzato e di verificare se qualcuno di essi sia andato a buon fine.

L'analisi ha rilevato un **attacco brute force SSH automatizzato, distribuito e persistente**: 33.253 tentativi di login falliti in 8 giorni, con 182 indirizzi IP esterni oltre la soglia di detection; i più aggressivi hanno colpito tutti e quattro i server provando ciascuno oltre 120 nomi utente diversi con priorità agli account privilegiati e di sistema (`root`, `administrator`, `admin`). Lo schema osservato, molti utenti diversi per ogni IP e attività costante giorno dopo giorno, è tipico di una botnet che scansiona Internet alla ricerca di credenziali deboli e non di un attacco mirato.

La correlazione tra login falliti e login riusciti ha inizialmente restituito tre indirizzi. L'analisi ha dimostrato che si tratta di **falsi positivi**: tre postazioni della rete interna con un solo utente ciascuna, che rappresentano la totalità dei 1.599 accessi riusciti del periodo. Dopo il tuning della regola, il risultato è **0 accessi riusciti da IP attaccanti esterni: nessuna compromissione rilevata**.

33.253	182	4 / 4	0
login SSH falliti in 8 giorni	IP esterni oltre la soglia di detection	server colpiti da ogni IP più aggressivo	accessi riusciti da IP attaccanti esterni

Il rischio residuo resta comunque significativo: i server espongono SSH con autenticazione tramite password a indirizzi Internet arbitrari, e la sola assenza di compromissioni nel periodo osservato non ne garantisce l'assenza in futuro. Le raccomandazioni prioritarie (sezione 9) sono la disabilitazione dell'autenticazione via password a favore delle chiavi SSH, la restrizione dell'accesso SSH a VPN o IP autorizzati e l'introduzione di un blocco automatico degli IP (fail2ban).

2. SCOPE E OBIETTIVI

Obiettivi dell'analisi

1. Identificare gli indirizzi IP sorgente di attività brute force SSH.
2. Quantificare volume e andamento temporale dell'attacco.
3. Identificare gli account presi di mira e dedurre la natura dell'attacco (mirato o automatizzato).
4. Verificare se un attaccante sia riuscito ad autenticarsi (possibile compromissione).
5. Realizzare una dashboard SOC riutilizzabile per il monitoraggio.
6. Proporre contromisure tecniche e organizzative.

In scope

- Log di autenticazione SSH (`secure.log`) dei server `mailsv1`, `www1`, `www2`, `www3`.
- Sviluppo e validazione delle query SPL di detection e correlazione.
- Costruzione della dashboard in Splunk Dashboard Studio.

Out of scope

- Log del web server e delle vendite (`access_combined_wcookie`, `vendor_sales`), censiti solo nell'inventario dei dati.
- Azioni di risposta attiva (blocco degli IP, modifica delle configurazioni dei server).
- Arricchimento degli IP con fonti di threat intelligence esterne.

3. AMBIENTE E DATASET

3.1 Inventario dei dati

Prima di qualsiasi ricerca è stato verificato cosa fosse effettivamente indicizzato, con l'intervallo temporale impostato su **All time**: i timestamp del dataset sono concentrati in un periodo passato e con gli intervalli predefiniti (ultime 24 ore o tempo reale) le ricerche non restituirebbero risultati.

QUERY 1 – INVENTARIO PER SOURCETYPE

```
source="tutorialdata.zip:*" | stats count by sourcetype
```

Sourcetype	Contenuto	Eventi
`access_combined_wcookie`	Log HTTP del web server (richieste al negozio online)	39.532
`vendor_sales/vendor_sales`	Transazioni di vendita	30.244
`www1/secure`	Log di autenticazione SSH dei 4 server – **oggetto dell'analisi**	40.088
Totale		**109.864**

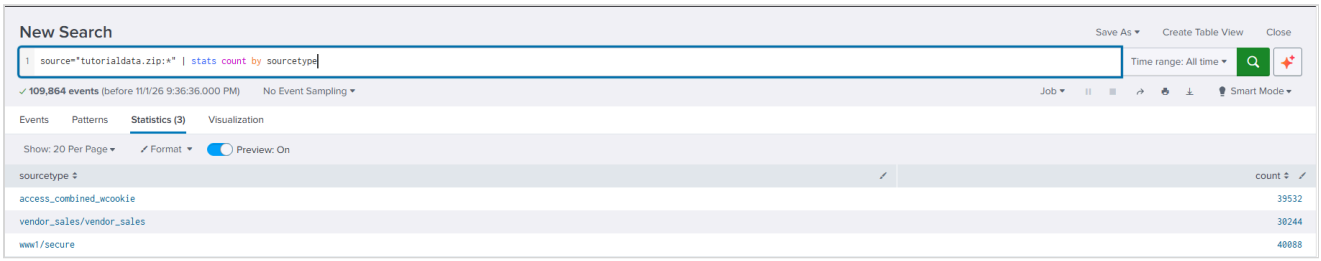


Figura 1 – Inventario dei dati indicizzati: 109.864 eventi suddivisi in 3 sourcetype

3.2 Anatomia di un evento di autenticazione

Un evento tipico del sourcetype `www1/secure`, generato dal demone `sshd`, ha questa forma:

```
Thu Aug 25 2026 22:39:53 mailsv1 sshd[5276]: Failed password for invalid user appserver
from 194.8.74.23 port 3351 ssh2
```

Porzione dell'evento	Significato
`Thu Aug 25 2026 22:39:53`	Data e ora del tentativo
`mailsv1`	Server che ha ricevuto il tentativo
`sshd[5276]`	Processo SSH e relativo PID
`Failed password`	Esito: password errata (in caso di successo: `Accepted password`)
`invalid user`	L'utente non esiste sul server: indizio di enumerazione “alla cieca”
`appserver`	Nome utente provato
`194.8.74.23 port 3351`	IP sorgente e porta sorgente del client

> **NOTA SULLA QUALITÀ DEI DATI**
>
> Il campo `host` vale `EpicodeServer` per tutti gli eventi, perché indica la macchina da cui i file sono stati caricati e non il server che li ha generati. Allo stesso modo, il sourcetype `www1/secure` raccoglie i `secure.log` di tutti e quattro i server. Il server reale è quindi stato **estratto dal testo dell'evento** (sezione 5.2) e non dai metadati. In un ambiente di produzione questo andrebbe corretto in fase di onboarding, assegnando host e sourcetype corretti (ad esempio `linux_secure`) a ogni sorgente.

4. METODOLOGIA

L'analisi segue il flusso di lavoro tipico di un analista SOC: dalla validazione dei dati alla detection, dalla verifica dei risultati alla loro presentazione. Tutte le ricerche sono state eseguite in Splunk Search & Reporting con intervallo **All time**.

1. **Inventario e validazione dei dati**: verifica di cosa è indicizzato e di quanto sono affidabili i campi.
2. **Filtraggio**: isolamento degli eventi di autenticazione fallita.
3. **Estrazione dei campi**: espressioni regolari (`rex`) per server, utente e IP sorgente.
4. **Aggregazione e soglia**: conteggio dei tentativi per IP e applicazione di una soglia di detection.
5. **Analisi di contesto**: andamento temporale e account presi di mira.
6. **Correlazione**: ricerca di IP con tentativi falliti seguiti da accessi riusciti.
7. **Validazione e tuning**: analisi dei risultati, individuazione dei falsi positivi, raffinamento della regola.
8. **Visualizzazione e raccomandazioni**: dashboard SOC, mappatura MITRE ATT&CK, contromisure.

5. ANALISI PASSO PER PASSO

5.1 Passo 1 – Isolare i login falliti

QUERY 2 – EVENTI DI AUTENTICAZIONE FALLITA

```
1  sourcetype="www1/secure" "Failed password"
```

La ricerca restituisce **33.253 eventi**, pari all'83% di tutti gli eventi del sourcetype di sicurezza (40.088). Già la lettura dei primi risultati è indicativa: lo stesso IP, `194.8.74.23`, nello stesso secondo prova `root`, `apache`, `mail`, `games` e utenti inesistenti come `appserver`, `testuser` e `mongodb`. Più tentativi nello stesso secondo, ciascuno su un utente diverso, non sono compatibili con un essere umano: si tratta di uno strumento automatizzato che scorre un dizionario di nomi utente.

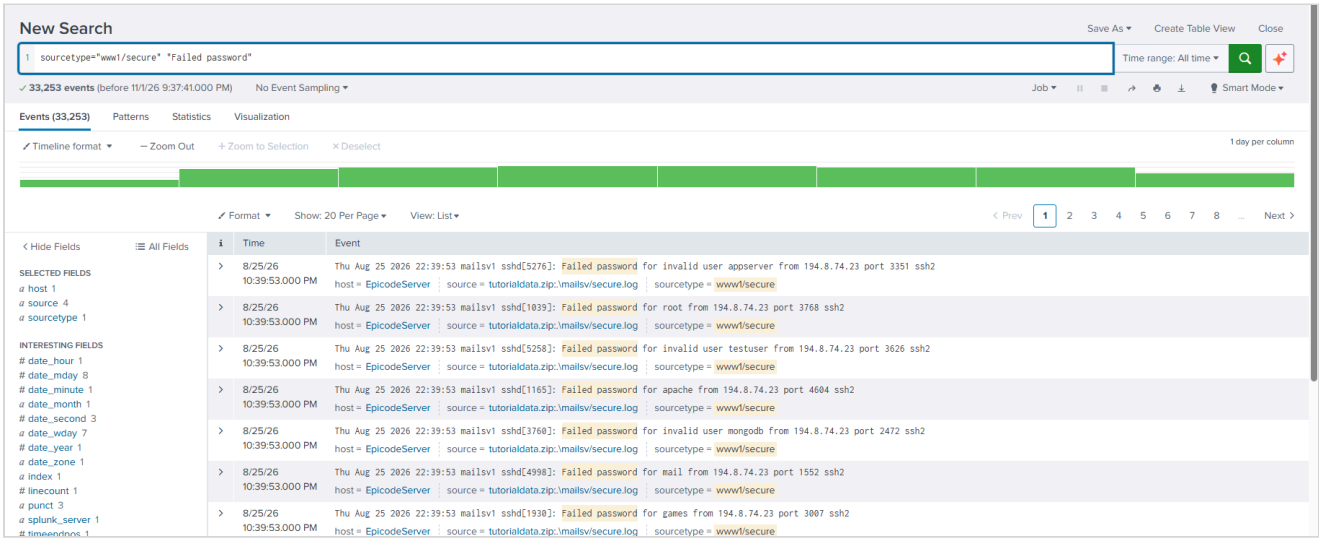


Figura 2 – Eventi "Failed password": lo stesso IP prova utenti diversi nello stesso secondo

5.2 Passo 2 – Estrarre i campi con `rex`

Il sourcetype non dispone di field extraction per utente, IP e server. I campi vengono quindi estratti al momento della ricerca (approccio *schema-on-read* di Splunk) con due espressioni regolari a gruppi nominati:

Espressione	Cosa estrae
`\d{2}:\d{2}:\d{2} (?<server>\S+) sshd`	Il nome del server, cioè la parola che segue l'orario e precede `sshd` → campo `server`
`for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})`	L'utente provato, saltando la dicitura opzionale "invalid user " → campo `utente`; l'indirizzo IPv4 che segue `from` → campo `src_ip`

Il gruppo opzionale `(invalid user )?` è essenziale: senza di esso la regex catturerebbe la parola "invalid" come nome utente per tutti i tentativi su account inesistenti, falsando le statistiche.

5.3 Passo 3 – Detection per IP sorgente

QUERY 3 – DETECTION BRUTE FORCE PER IP

```
sourcetype="www1/secure" "Failed password"
| rex "\d{2}:\d{2}:\d{2} (?<server>\S+) sshd"
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| stats count AS tentativi dc(utente) AS utenti_provati values(server) AS server_colpiti by src_ip
| where tentativi > 10
| sort - tentativi
| eval server_colpiti=mvjoin(server_colpiti, ", ")
```

Comando	Funzione
`stats count AS tentativi`	Numero di login falliti per ogni IP sorgente
`dc(utente) AS utenti_provati`	*Distinct count*: quanti nomi utente **diversi** ha provato l'IP. È l'indicatore chiave per distinguere un attacco a dizionario da un utente che sbaglia la propria password
`values(server)`	Elenco dei server colpiti da ciascun IP
`where tentativi > 10`	Soglia di detection: oltre 10 fallimenti l'attività non è più attribuibile a un errore occasionale
`sort - tentativi`	Ordina dal più aggressivo, come serve a chi fa il triage
`mvjoin(…, ", ")`	Unisce i server in un'unica riga separata da virgole, per una tabella leggibile in dashboard

Risultato: 185 indirizzi IP superano la soglia. Di questi, 3 sono postazioni della rete interna che verranno analizzate al passo 6, quindi gli **IP esterni sospetti sono 182**. I più aggressivi:

IP sorgente	Tentativi	Utenti provati	Server colpiti
87.194.216.51	948	140	mailsv1, www1, www2, www3
211.166.11.101	743	135	mailsv1, www1, www2, www3
128.241.220.82	622	129	mailsv1, www1, www2, www3
109.169.32.135	515	122	mailsv1, www1, www2, www3
194.215.205.19	514	128	mailsv1, www1, www2, www3
216.221.226.11	433	124	mailsv1, www1, www2, www3

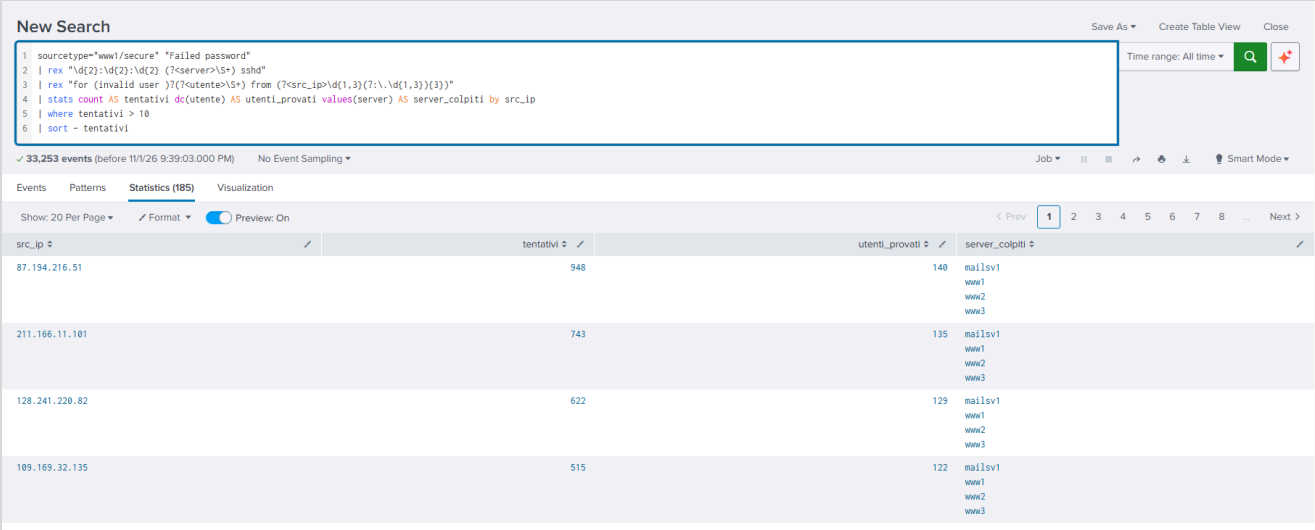


Figura 3 – Risultato della detection: 185 IP oltre la soglia, ordinati per numero di tentativi

> **INTERPRETAZIONE**
>
> Ogni IP del vertice ha provato oltre 120 utenti diversi, con 4–7 tentativi per utente, e ha colpito **tutti e quattro i server**. Non si tratta di qualcuno che ha dimenticato la password, ma di sorgenti che scansionano l'intera infrastruttura con un dizionario di credenziali. La distribuzione su centinaia di IP con lo stesso comportamento è tipica di una botnet, ed è anche ciò che rende inefficace il blocco manuale di singoli indirizzi.

5.4 Passo 4 – Andamento temporale

Il primo tentativo, con `timechart span=1h`, ha prodotto un grafico illeggibile: nel dataset gli eventi di ogni giornata sono concentrati in una sola fascia oraria, e il grafico orario mostrava picchi isolati tra centinaia di intervalli a zero. La granularità è stata quindi portata a un giorno.

QUERY 4A – TENTATIVI FALLITI PER GIORNO (RICERCA)

```
sourcetype="www1/secure" "Failed password"
| timechart span=1d count AS tentativi_falliti
```

Nella dashboard, con intervallo globale *All time*, `timechart` estende l'asse fino alla data corrente riempiendolo di giorni vuoti e schiaccia gli 8 giorni con dati in un angolo del grafico. Per il pannello è stata quindi usata una variante con `bin` e `stats`, che genera solo i giorni effettivamente presenti:

QUERY 4B – TENTATIVI FALLITI PER GIORNO (PANNELLO DASHBOARD)

```
sourcetype="www1/secure" "Failed password"
| bin _time span=1d
| stats count AS tentativi_falliti by _time
| eval giorno=strftime(_time,"%d/%m")
| table giorno tentativi_falliti
```

Giorno	18/08	19/08	20/08	21/08	22/08	23/08	24/08	25/08
Tentativi falliti	1.667	4.284	4.709	**5.034**	5.009	4.706	4.617	3.227

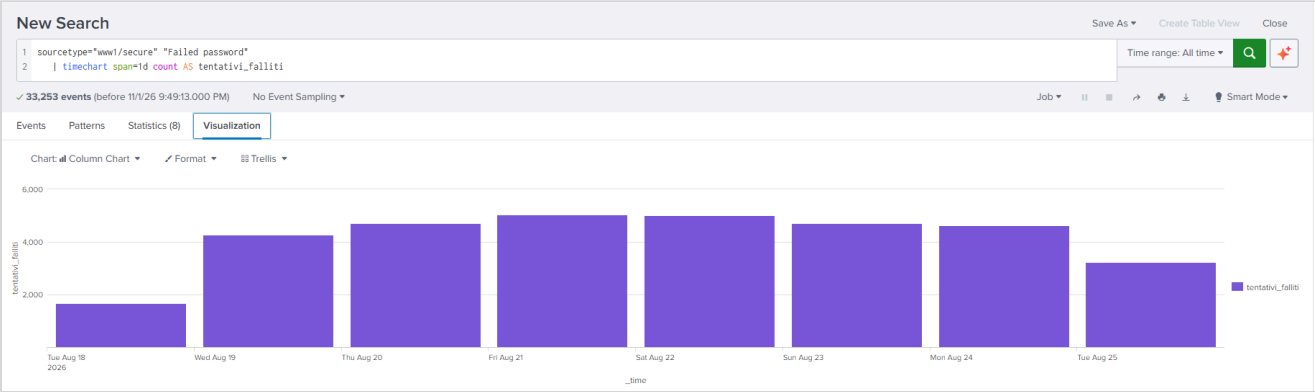


Figura 4 – Tentativi di login falliti per giorno: pressione costante per tutto il periodo osservato

> **INTERPRETAZIONE**
>
> Il primo e l'ultimo giorno hanno volumi inferiori, coerenti con un periodo di log che inizia e termina a giornata già avviata. Nei sei giorni centrali l'attacco si stabilizza tra 4.284 e 5.034 tentativi al giorno, con una media di circa 4.700, cioè quasi 200 tentativi l'ora, e un picco il 21 agosto. Non è un episodio isolato ma una **pressione continua e automatizzata**, che proseguirebbe finché i server restano esposti.

5.5 Passo 5 – Account presi di mira

QUERY 5 – TOP 10 UTENTI ATTACCATI

```
sourcetype="www1/secure" "Failed password"
| rex "for (invalid user )?(?<utente>\S+) from"
| top limit=10 utente showperc=false
```

L'opzione `showperc=false` rimuove la colonna percentuale che `top` aggiunge di default, e che nel grafico a barre apparirebbe come una seconda serie priva di significato.

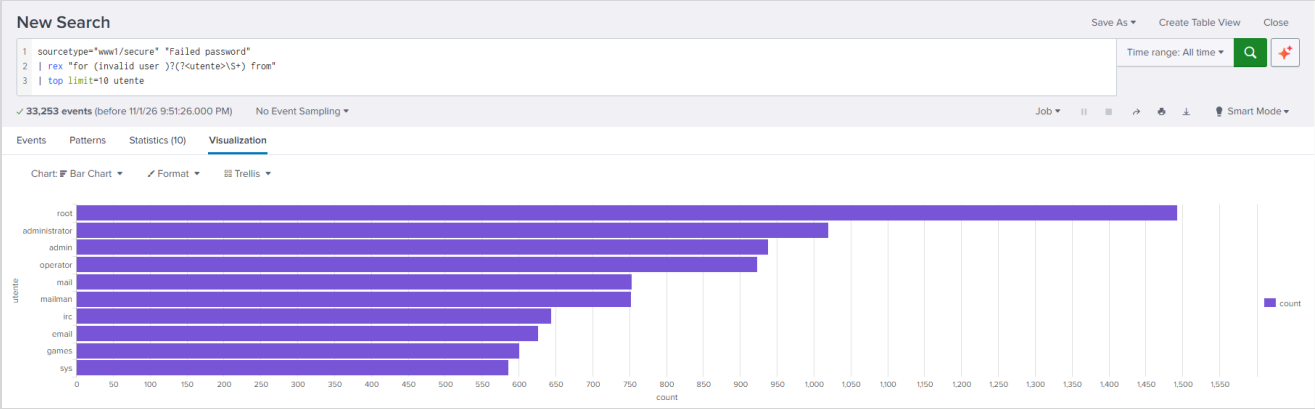


Figura 5 – I 10 nomi utente più bersagliati

#	Utente	Tentativi	Tipologia
1	`root`	≈ 1.490	Superutente Linux: un solo accesso riuscito dà il controllo totale del server
2	`administrator`	≈ 1.020	Nomi amministrativi generici o predefiniti
3	`admin`	≈ 935	
4	`operator`	≈ 925	
5–10	`mail, mailman, irc, email, games, sys`	≈ 585–750	Account di sistema presenti di default su molte distribuzioni Linux

Valori approssimati, letti dal grafico della Figura 5.

> **INTERPRETAZIONE**
>
> L'attaccante non conosce i nomi reali degli utenti dell'azienda: prova account privilegiati e account di sistema che *probabilmente* esistono su qualsiasi server Linux. È la firma di un **attacco a dizionario non mirato**. La forte presenza di `root` rende prioritaria la verifica che il login diretto del superutente via SSH sia disabilitato.

5.6 Passo 6 – Correlazione: fallimenti seguiti da un accesso riuscito

Il passo più importante è verificare se un attaccante sia riuscito a entrare. La regola cerca gli IP che hanno **sia** più di 10 fallimenti **sia** almeno un accesso riuscito.

QUERY 6 – CORRELAZIONE (PRIMA VERSIONE)

```
sourcetype="www1/secure" ("Failed password" OR "Accepted password")
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| eval esito=if(like(_raw,"%Accepted password%"),"riuscito","fallito")
| stats count(eval(esito="fallito")) AS falliti count(eval(esito="riuscito")) AS riusciti
values(utente) AS utenti by src_ip
| where falliti > 10 AND riusciti > 0
```

Il comando `eval` classifica ogni evento come “riuscito” o “fallito”; `count(eval(...))` conta separatamente i due esiti per ciascun IP all'interno di un unico `stats`.

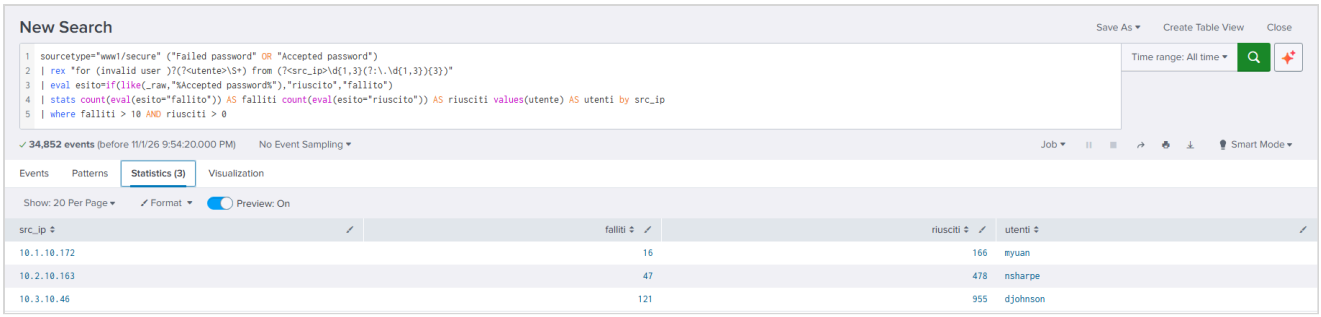


Figura 6 – Prima versione della correlazione: 3 indirizzi restituiti

IP sorgente	Falliti	Riusciti	Utente	Rapporto successi / fallimenti
10.1.10.172	16	166	myuan	≈ 10 : 1
10.2.10.163	47	478	nsharpe	≈ 10 : 1
10.3.10.46	121	955	djohnson	≈ 8 : 1

VALIDAZIONE DEL RISULTATO: FALSI POSITIVI

I tre indirizzi presentano tutte le caratteristiche di un'attività legittima:

- appartengono alla rete privata `10.0.0.0/8` (RFC 1918), quindi interna all'azienda;
- ognuno usa **un solo utente**, sempre lo stesso, invece di centinaia;
- gli accessi riusciti sono 8–10 volte i fallimenti: è il profilo di un dipendente che entra ogni giorno e ogni tanto sbaglia la password.

Verifica incrociata: la ricerca combinata restituisce 34.852 eventi, di cui 33.253 falliti, quindi gli accessi riusciti del periodo sono **1.599**. La somma degli accessi riusciti delle tre postazioni (166 + 478 + 955) è esattamente **1.599**: **tutti gli accessi SSH riusciti del periodo provengono da queste tre postazioni interne**, e nessuno da un indirizzo esterno.

5.7 Passo 7 – Tuning della regola e risultato finale

La regola è stata rifinita escludendo la rete interna, così da segnalare solo il caso realmente critico: un **IP esterno** che fallisce ripetutamente e poi riesce ad autenticarsi.

QUERY 7 – CORRELAZIONE RIFINITA (REGOLA FINALE)

```
sourcetype="www1/secure" ("Failed password" OR "Accepted password")
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| eval esito=if(like(_raw,"%Accepted password%"),"riuscito","fallito")
| stats count(eval(esito="fallito")) AS falliti count(eval(esito="riuscito")) AS riusciti
by src_ip
| where falliti > 10 AND riusciti > 0 AND NOT cidrmatch("10.0.0.0/8", src_ip)
| stats count AS ip_esterni_con_accesso_riuscito
```

La funzione `cidrmatch()` verifica se un indirizzo appartiene a una sottorete; preceduta da `NOT`, esclude gli host interni. L'ultimo `stats count` riduce il risultato a un unico numero, adatto a un pannello *Single Value*.

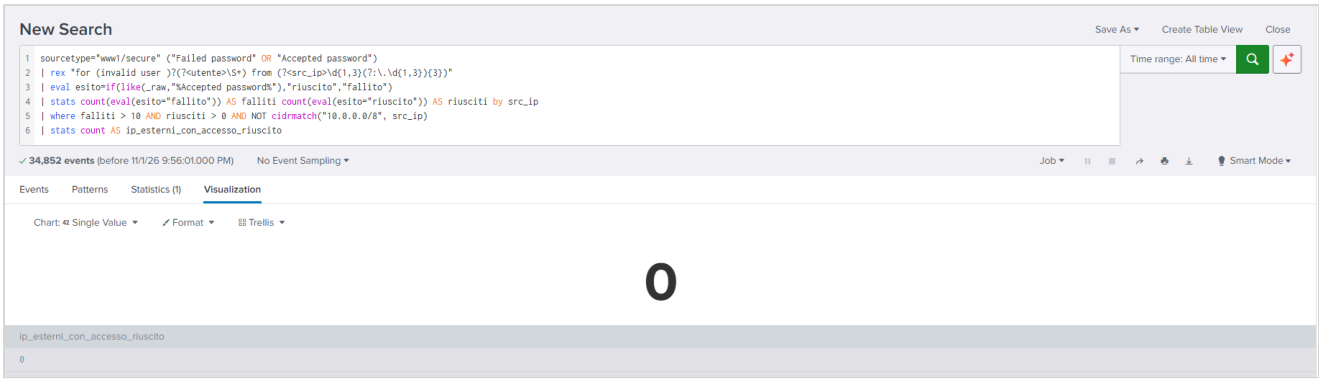


Figura 7 – Regola finale: 0 accessi riusciti da IP attaccanti esterni

Risultato: 0. Nessuno dei 182 IP esterni che hanno condotto l'attacco è riuscito ad autenticarsi su alcun server. Il passaggio dalla regola grezza a quella rifinita, cioè **analizzare i risultati, riconoscere i falsi positivi e ridurre il rumore** senza perdere la capacità di rilevare il caso critico, è il cuore del lavoro quotidiano di un analista SOC.

6. DASHBOARD SOC

Le query sono state raccolte nella dashboard **"SOC – SSH Brute Force Detection"**, realizzata in Splunk Dashboard Studio (layout a griglia, intervallo globale predefinito *All time*). I pannelli sono ordinati per essere letti dall'alto verso il basso come un report: prima l'esito, poi i dettagli.

#	Pannello	Visualizzazione	Domanda a cui risponde
1	Accessi riusciti da IP attaccanti esterni	Single Value	Qualcuno è entrato? **Esito: 0**
2	IP sospetti di brute force (>10 tentativi)	Tabella	Chi sta attaccando, con quale intensità e su quali server?
3	Tentativi di login falliti per giorno	Column chart	Quando? L'attacco è episodico o continuo?
4	Top 10 utenti presi di mira	Bar chart	Cosa cerca l'attaccante? Attacco mirato o a dizionario?

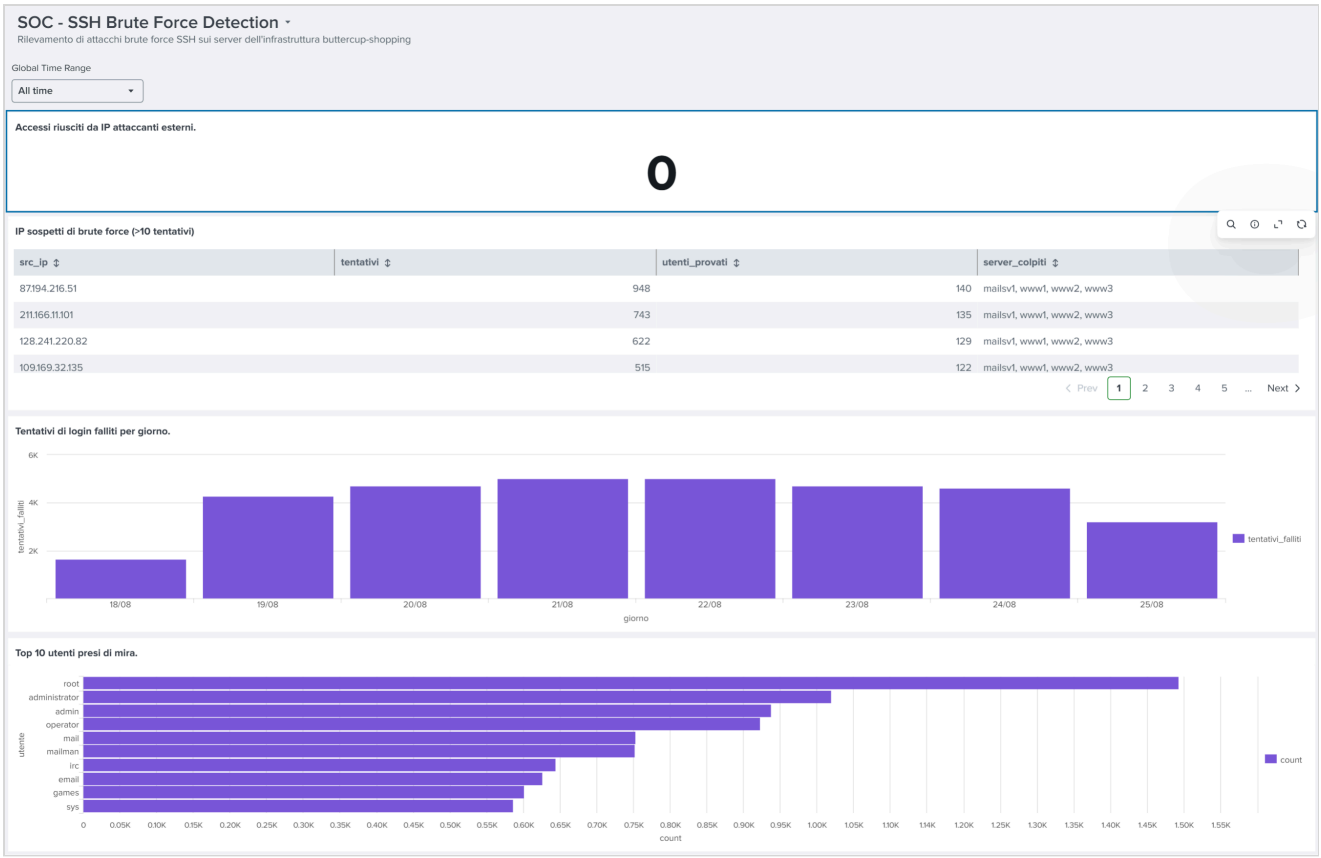


Figura 8 – Dashboard "SOC – SSH Brute Force Detection" in Splunk Dashboard Studio

Rifiniture applicate in fase di costruzione: intervallo globale predefinito portato da "Last 24 hours" ad "All time"; `mvjoin` per mostrare i server su una sola riga; `showperc=false` per eliminare la serie percentuale dal grafico degli utenti; `bin` + `stats` al posto di `timechart` per un asse dei giorni limitato al periodo con dati.

7. MAPPATURA MITRE ATT&CK

Tattica	Tecnica	Evidenza nei log
Credential Access (TA0006)	**T1110 – Brute Force**	33.253 tentativi di autenticazione SSH falliti su 4 server; 182 IP esterni oltre la soglia di detection
Credential Access (TA0006)	T1110.001 – Password Guessing T1110.003 – Password Spraying	Centinaia di utenti provati per IP con pochi tentativi ciascuno. I log non riportano le password usate, quindi non è possibile distinguere con certezza tra le due sotto-tecniche: lo schema è compatibile con entrambe
Initial Access (TA0001)	T1078 – Valid Accounts	Esito che l'attacco mira a ottenere e che la regola finale (Query 7) è progettata per rilevare. **Non osservato** nel periodo analizzato

8. FINDINGS E VALUTAZIONE DEL RISCHIO

ID	Finding	Severità	Evidenza e impatto
F-01	Servizio SSH raggiungibile da Internet con autenticazione tramite password	ALTA	182 IP esterni ricevono risposte `Failed password` su tutti i 4 server: il servizio è esposto e accetta password. È la condizione che rende possibile l'attacco; una sola credenziale debole porterebbe alla compromissione
F-02	Attacco brute force SSH distribuito e persistente	MEDIA	Circa 4.700 tentativi al giorno, costanti per 8 giorni, da una sorgente distribuita. Nessuna compromissione, ma pressione continua che aumenta la probabilità di successo nel tempo
F-03	Nessuna evidenza di blocco automatico degli IP attaccanti	MEDIA	Lo stesso IP (87.194.216.51) ha potuto eseguire 948 tentativi su tutti i server: non risulta attivo un meccanismo di rate-limiting o ban (es. fail2ban)
F-04	Account privilegiati e di sistema esposti ai tentativi	MEDIA	`root` è l'utente più attaccato (≈ 1.490 tentativi). Dai log non è verificabile se il login SSH di root sia disabilitato: va controllato in `sshd_config`
F-05	Metadati di onboarding non affidabili	BASSA	Campo `host` uguale per tutti gli eventi e sourcetype unico per 4 server: rallenta le indagini e può far perdere correlazioni
F-06	Nessun accesso riuscito da IP esterni	INFO	Regola finale = 0. Tutti i 1.599 accessi riusciti provengono da 3 postazioni interne con attività legittima

9. RACCOMANDAZIONI E MITIGAZIONI

Priorità	Azione	Dettaglio
ALTA	Autenticazione SSH solo con chiave	Disabilitare le password e il login diretto di root (configurazione sotto). Annulla l'efficacia di qualsiasi attacco a dizionario. Risolve F-01 e F-04
ALTA	Restringere l'accesso SSH	Consentire la porta 22 solo da VPN aziendale o da una whitelist di IP amministrativi tramite firewall perimetrale. Elimina l'esposizione a Internet. Risolve F-01
MEDIA	Blocco automatico degli IP	Installare fail2ban (o equivalente) per bannare gli IP dopo N fallimenti in una finestra temporale. Risolve F-03
MEDIA	Ridurre la superficie degli account	Assegnare `/usr/sbin/nologin` agli account di sistema senza necessità di login (`games`, `irc`, `mail`, ...) e limitare SSH ai soli utenti autorizzati con `AllowUsers` / `AllowGroups`
MEDIA	MFA sugli accessi amministrativi	Secondo fattore per gli accessi privilegiati, anche dopo il passaggio alle chiavi
MEDIA	Alerting in tempo reale	Trasformare la Query 7 in un alert ad alta priorità e la detection per IP in un alert a finestra temporale (sezione 10). Richiede una licenza Splunk Enterprise: la licenza Free non supporta gli alert programmati
BASSA	Correggere l'onboarding dei log	Host corretto per ciascun server e sourcetype standard (`linux_secure`) con field extraction predefinite. Risolve F-05

ESEMPIO – /ETC/SSH/SSHD_CONFIG

```
# Solo autenticazione a chiave pubblica
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
# Nessun login diretto del superutente
PermitRootLogin no
# Limite di tentativi per connessione e utenti ammessi
MaxAuthTries 3
AllowGroups sshusers
```

ESEMPIO – /ETC/FAIL2BAN/JAIL.LOCAL

```
[sshd]
enabled  = true
maxretry = 5
findtime = 10m
bantime  = 1h
```

10. LIMITI DELL'ANALISI E SVILUPPI FUTURI

- **Soglia statica sull'intero periodo.** La soglia di 10 tentativi è calcolata su 8 giorni: le postazioni interne la superano per puro volume (fino a 121 fallimenti in 8 giorni). In produzione la detection va applicata su una finestra temporale breve e affiancata dal numero di utenti distinti, come nella regola proposta sotto.
- **Correlazione non sequenziale.** La Query 7 verifica la presenza di fallimenti e successi per lo stesso IP, non il loro ordine. Una versione evoluta può usare `streamstats` o `transaction` per confermare che il successo arrivi *dopo* la serie di fallimenti.
- **Whitelist ridotta a 10.0.0.0/8.** In un ambiente reale l'esclusione va estesa a tutte le reti private e gestita con una lookup di asset e range VPN autorizzati, mantenuta nel tempo.
- **Nessun arricchimento degli IP.** Sviluppo naturale: geolocalizzazione con `iplocation` e confronto con fonti di reputazione (es. AbuseIPDB) per dare priorità agli indirizzi noti.
- **Dataset didattico.** I log sono simulati (Splunk Tutorial Data). Metodo e query sono però gli stessi applicabili a log `sshd` reali.

PROPOSTA – REGOLA DI ALERT A FINESTRA TEMPORALE (NON ESEGUITA IN LABORATORIO)

```
sourcetype="www1/secure" "Failed password"
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| where NOT cidrmatch("10.0.0.0/8", src_ip)
| bin _time span=5m
| stats count AS tentativi dc(utente) AS utenti_provati by _time src_ip
| where tentativi >= 20 OR utenti_provati >= 5
```

11. CONCLUSIONI

L'analisi ha permesso di rilevare, caratterizzare e contestualizzare un attacco brute force SSH su larga scala: 33.253 tentativi falliti in 8 giorni, 182 IP esterni oltre la soglia di detection e tutti e quattro i server colpiti, con un dizionario di account privilegiati e di sistema. La correlazione tra fallimenti e accessi riusciti, rifinita dopo l'eliminazione di tre falsi positivi interni, ha stabilito che **nessun attaccante è riuscito ad autenticarsi**.

L'esito favorevole non deve però far abbassare la guardia: la causa dell'attacco, cioè l'esposizione di SSH a Internet con autenticazione via password, è ancora presente. Le misure ad alta priorità della sezione 9 la eliminerebbero alla radice, mentre la dashboard e le regole sviluppate permettono di monitorare l'efficacia delle contromisure nel tempo.

Competenze applicate

- Linguaggio SPL: `rex`, `stats`, `eval`, `timechart`, `bin`, `top`, funzioni `dc`, `values`, `cidrmatch`, `mvjoin`, `strftime`
- Espressioni regolari con gruppi nominati per l'estrazione di campi *schema-on-read*
- Correlazione di eventi, validazione dei risultati e tuning dei falsi positivi
- Progettazione di una dashboard SOC in Splunk Dashboard Studio
- Mappatura su MITRE ATT&CK e hardening di SSH (sshd, fail2ban)

APPENDICE A – QUERY SPL COMPLETE

Tutte le query sono eseguite in Splunk Search & Reporting con intervallo **All time**.

Q1 – INVENTARIO DEI DATI

```
source="tutorialdata.zip:*" | stats count by sourcetype
```

Q2 – LOGIN FALLITI

```
sourcetype="www1/secure" "Failed password"
```

Q3 – DETECTION BRUTE FORCE PER IP (PANNELLO “IP SOSPETTI”)

```
sourcetype="www1/secure" "Failed password"
| rex "\d{2}:\d{2}:\d{2} (?<server>\S+) sshd"
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| stats count AS tentativi dc(utente) AS utenti_provati values(server) AS server_colpiti by src_ip
| where tentativi > 10
| sort - tentativi
| eval server_colpiti=mvjoin(server_colpiti, ", ")
```

Q4 – TENTATIVI FALLITI PER GIORNO (PANNELLO DASHBOARD)

```
sourcetype="www1/secure" "Failed password"
| bin _time span=1d
| stats count AS tentativi_falliti by _time
| eval giorno=strftime(_time,"%d/%m")
| table giorno tentativi_falliti
```

Q5 – TOP 10 UTENTI PRESI DI MIRA

```
sourcetype="www1/secure" "Failed password"
| rex "for (invalid user )?(?<utente>\S+) from"
| top limit=10 utente showperc=false
```

Q6 – CORRELAZIONE FALLIMENTI / SUCCESSI (PRIMA VERSIONE)

```
sourcetype="www1/secure" ("Failed password" OR "Accepted password")
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| eval esito=if(like(_raw,"%Accepted password%"),"riuscito","fallito")
| stats count(eval(esito="fallito")) AS falliti count(eval(esito="riuscito")) AS riusciti values(utente) AS utenti by src_ip
| where falliti > 10 AND riusciti > 0
```

Q7 – ACCESSI RIUSCITI DA IP ESTERNI (REGOLA FINALE, PANNELLO SINGLE VALUE)

```
sourcetype="www1/secure" ("Failed password" OR "Accepted password")
| rex "for (invalid user )?(?<utente>\S+) from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| eval esito=if(like(_raw,"%Accepted password%"),"riuscito","fallito")
| stats count(eval(esito="fallito")) AS falliti count(eval(esito="riuscito")) AS riusciti
by src_ip
| where falliti > 10 AND riusciti > 0 AND NOT cidrmatch("10.0.0.0/8", src_ip)
| stats count AS ip_esterni_con_accesso_riuscito
```

APPENDICE B – NOTA SULLA LICENZA

L'analisi è stata svolta con **Splunk Enterprise 10.4.2 in licenza Free**, attivata dopo la scadenza della licenza Enterprise Trial di 60 giorni. La licenza Free mantiene pienamente funzionanti ricerche e dashboard, ma non supporta gli alert programmati e l'autenticazione multiutente: per questo le regole di alert sono proposte nella sezione 10 e non sono state attivate. In un ambiente di produzione si opererebbe con licenza Enterprise, utenti nominali e ruoli (RBAC).